

AI Risk & Security Strategy Report

Contoso Financial Service • Azure OpenAI Knowledge Assistant Initiative

Prepared for	Executive Risk Committee — Chief Risk Officer, Chief Information Security Officer, Chief Compliance Officer
Prepared by	AI Governance Lead, Contoso Financial Service
Date	26 August 2026
Decision requested	Go / no-go on production deployment of the GenAI knowledge assistant
Classification	Internal — Executive Risk Committee deliberation
Supporting artifacts	AI Risk Register • FAIR Quantification Model • STRIDE Worksheet • ADR-001 • Governance Alignment Matrix

RECOMMENDATION: CONDITIONAL APPROVAL

Approve production deployment subject to eight conditions precedent delivered and verified before go-live, and three further commitments within 30 days of go-live. After controls, no risk remains in the High band. Unmitigated annualised loss exposure for the principal scenario is modelled at \$50,000 minimum, \$625,000 most likely, \$6,000,000 maximum.

Contents

- Section 1** Executive Summary
- Section 2** AI Initiative Overview
- Section 3** Risk Register Summary, Prioritization and Quantification
- Section 4** Threat Model Findings (STRIDE)
- Section 5** Control Alignment Matrix
- Section 6** Residual Risk Assessment
- Section 7** Governance Recommendation
- Appendix A** Consistency Cross-Check
- Appendix B** Documented Assumptions
- Appendix C** Framework Reference Verification
- Appendix D** Generative AI Usage Log (Audit Trail)

Section 1: Executive Summary

This section is written to be read on its own. A committee member who reads nothing else should be able to make the decision from it.

The initiative and the decision

Contoso Financial Service proposes to deploy an internal knowledge assistant built on Azure OpenAI, serving approximately 2,000 customer service, operations and compliance staff. The assistant retrieves and synthesises internal policy documents, product guides and procedural knowledge to answer employee questions in real time, returning citations to the source documents that grounded each answer. It is advisory and read-only: it answers questions, and it does not execute transactions, initiate workflows, or make decisions about customers. It has no customer-facing access, and no customer or employee personal data is admitted to the indexed corpus. The Executive Risk Committee is asked to decide whether production deployment should proceed.

Top risks and financial exposure

Eleven risks were assessed across the data, model and usage domains and mapped to all four NIST AI RMF core functions. After applying overlay factors for regulatory sensitivity, detection lag, control readiness and interaction effects, the three highest-priority risks are:

Risk	Name	Why it leads
R-01	Ingestion boundary failure	Regulator-notifiable, silent in accumulation, and almost entirely unbuilt. It is also the precondition that makes Contoso's largest modelled financial exposure possible.
R-02	Permission-trimming failure	Carries the highest single impact rating in the register, and is the only risk with no natural detection signal — a user shown more than their entitlement does not complain.
R-05	Prompt injection at the inference endpoint	A deliberate-adversary risk with immediate exploitation and a published, low-barrier technique base. Chained with R-01 it forms the quantified loss scenario.

A notable pattern: the top three are data and access risks, not model-behaviour risks. The instinctive concern with a GenAI assistant is that it will say something wrong. The analysis says the more material exposure is what the model is allowed to see, and who is allowed to see it back.

Financial exposure. FAIR quantification of the principal loss scenario — confidentiality breach of restricted content extracted via prompt injection (R-05), with ingestion boundary failure (R-01) as the enabling precondition — places unmitigated annualised loss exposure at **\$50,000 minimum, \$625,000 most likely, and \$6,000,000 maximum**. This is reported as a band throughout. A single-point figure would imply a precision the model does not support, given that Contoso has no assistant incident history from which to observe event frequency.

Threat findings and the controls that address them

A STRIDE assessment of the Azure OpenAI inference endpoint identified six threats, one in each category. Every threat traces back to a risk already in the register, and every threat is paired with a named mitigation in ADR-001 — six pairings, no orphans. Fourteen controls are mapped to Contoso's three corporate security strategy pillars. Only one of the fourteen runs in production today.

Two findings bear directly on the decision. First, nothing in the existing controls inventory enforces entitlement at retrieval, so once network isolation closes the external perimeter, over-permissive retrieval is the only remaining leakage path. Second, the inventory contains no data loss prevention capability at all — and sensitivity analysis shows ingestion controls reduce modelled maximum exposure by roughly 73 per cent against roughly 60 per cent for endpoint controls. The largest lever on the financial exposure is therefore the control set that is entirely absent.

Two claims in the existing inventory were also found to be inaccurate and are corrected in Section 5: input regex validation is recorded as having no structural coverage gaps, and Entra ID authentication is recorded as fully meeting the perimeter pillar. Neither holds.

Recommendation and residual risk posture

CONDITIONAL APPROVAL

Proceed with deployment, subject to eight conditions precedent delivered and independently verified before go-live, and three further commitments within 30 days of go-live. Each carries a named owner and a verification test.

Once the controls in Section 5 are delivered, no risk in the register remains in the High band. Five fall to Medium — R-01, R-02, R-04, R-05 and R-09 — and six fall to Low. That profile sits within the organisation's stated appetite for an internal, advisory system.

The reason the recommendation is conditional rather than unqualified is a single point of logic. **The residual profile above is a projected residual, not an observed one.** It assumes fourteen controls are in place, and thirteen of them are not. Approving unconditionally would be approving a control set that does not yet exist. Deferring would be disproportionate, because no risk is unacceptable in principle and every gap has an identified, costed and owned remedy. Conditional approval is the accurate description of where this initiative stands.

Should conditions CP-1 (retrieval entitlement enforcement) or CP-2 (ingestion boundary enforcement) prove undeliverable before go-live, the recommendation changes to DEFER. Without them, R-01 and R-02 remain at their inherent scores of 16 and 15, placing two risks in the High band and exceeding appetite.

One assumption should be visible to the committee at this level. No Record of Processing Activities excerpt was available for this initiative. The processing description in Appendix B is the author's reconstruction and requires confirmation by the Data Protection Officer before go-live. It is listed as low confidence and is not relied upon by any control in this report.

Section 2: AI Initiative Overview

2.1 What the system does and who uses it

The Contoso Financial Service GenAI Knowledge Assistant is an internal retrieval-augmented generation system built on Azure OpenAI. Staff ask questions in natural language; the system retrieves from an indexed corpus of approved internal knowledge and synthesises a grounded, citation-backed answer in real time.

User group	Typical use
Customer service staff	Product terms, fee schedules, servicing procedures, complaint-handling steps
Operations staff	Back-office processing procedures, exception handling, control steps
Compliance staff	Policy lookup, regulatory procedure reference, control-testing guidance

Approximately 2,000 staff across the three functions. No customer, contractor or third-party access.

2.2 Technical environment and integration

Layer	Integration
Access	Internal staff web portal and Microsoft Teams channel
Identity	Microsoft Entra ID single sign-on; token-based authentication with no static keys; group-based entitlements per function
Orchestration	API gateway enforcing rate limits and maximum token length per user
Inbound guardrails	Input validation and prompt-injection filtering before retrieval
Retrieval	Permission-trimmed vector index built from approved document repositories
Inference	Azure OpenAI Service in Contoso's private Azure tenant, reached over a private endpoint; no Contoso data used for model training
Outbound guardrails	Content filter with PII and confidentiality scrubbing; citation and groundedness enforcement
Audit	Microsoft Purview immutable telemetry — user ID, input prompt, retrieved document versions, model output hash

2.3 In scope

Ten components are assessed: the staff chat interface; the Entra ID authentication and entitlement layer; the API gateway and orchestration layer; the inbound guardrail layer; the document ingestion and indexing pipeline; the vector index and metadata store; the Azure OpenAI inference endpoint; the outbound content filter; the Purview telemetry store; and the answer-quality feedback loop.

Six data flows are assessed: staff prompt through gateway and guardrail to retrieval; approved documents through the ingestion pipeline to the index; retrieved context and prompt to the inference endpoint; completion through the outbound filter to the staff interface; all interactions to the immutable telemetry store; and staff feedback to the quality review queue.

Content in scope for ingestion is limited to an approved-source allow-list: internal policy documents and policy libraries, product guides, terms and fee schedules, and standard operating procedures and process manuals. All ingested content is classified, hashed and version-tagged before indexing.

2.4 Out of scope

Nothing in Sections 3 to 7 relies on, or claims coverage of, any item below. Referencing an excluded component in a later section would be a consistency failure, and Appendix A records the check.

Ref	Exclusion
X-1	Customer-facing or any external deployment — internal staff only
X-2	Live personal data of customers, employees or candidates in the indexed corpus
X-3	Corporate financial disclosures, market strategies, unreleased product roadmaps
X-4	Individual compensation, bonuses, performance reviews, employment contracts
X-5	Automated workflow execution or transaction initiation by the assistant
X-6	Autonomous decisioning about customers — credit, AML, eligibility, pricing
X-7	Model fine-tuning or training on Contoso data
X-8	Security certification of the underlying Azure platform, inherited from cloud provider assurance
X-9	Unsanctioned public GenAI tool use by staff, handled as a separate governance workstream
X-10	The HR onboarding assistant use case, which is a separate initiative
X-11	Third-party risk assessment of Microsoft as a supplier, handled by the existing TPRM programme

2.5 Stakeholders

This list is fixed for the report. Risk owners named in Section 3 are drawn only from it.

Stakeholder	Interest and accountability
Executive Risk Committee (CRO, CISO, CCO)	Deployment decision; residual risk acceptance
AI Governance Lead	Report author; risk register owner; governance framework
Head of Information Security	Endpoint controls, threat mitigations, ADR ownership
Data Protection Officer	Personal data processing, records of processing, retention
Compliance Operations Manager	Regulatory alignment; accuracy of compliance answers
Head of Platform Engineering	Azure tenant, deployment, availability
Product Owner, Knowledge Assistant	Corpus curation, user experience, feedback loop
Customer Service Operations Director	Business use; front-line answer quality
Operations Director	Business use; procedural accuracy
Internal Audit	Independent assurance over the audit trail
End users (CS, operations, compliance staff)	Day-to-day use; misuse and over-reliance exposure

2.6 Assumptions

Ten assumptions were required because the scenario brief does not state them. They are listed in full with confidence ratings in Appendix B. Three warrant mention here: the platform is assumed to be Azure OpenAI (A-01); the subject is the knowledge assistant rather than the HR onboarding assistant the brief is titled for (A-02); and no Record of Processing Activities was supplied, so the processing description is reconstructed and carries low confidence pending Data Protection Officer confirmation (A-03).

Section 3: Risk Register Summary

3.1 Method

Risks were discovered across the three AI risk domains — data, model and usage — and each was mapped to one of the four NIST AI RMF core functions. All four functions are represented. Scores are Likelihood multiplied by Impact on a 1 to 5 scale, banded 1–5 Low, 6–12 Medium, 13–25 High.

Residual scores are calculated rather than asserted, on a stated convention: preventive controls reduce likelihood, detective and response controls reduce impact, and where neither applies the value is held and the rationale says so. Every one of the twenty-two residual movements is justified in the register workbook.

The names and identifiers below are canonical. No risk is introduced anywhere later in this report.

3.2 The register

Risk ID	Domain	NIST	Risk name	L	I	Inherent	Residual	Owner
R-01	Data	Map	Ingestion boundary failure	4	4	16	8	Data Protection Officer
R-02	Data	Measure	Permission-trimming failure	3	5	15	8	Head of Information Security
R-03	Data	Manage	Corpus staleness and tampering	4	3	12	4	Product Owner, Knowledge Assistant
R-04	Model	Measure	Ungrounded regulated answer	4	4	16	6	Compliance Operations Manager
R-05	Model	Manage	Prompt injection at the inference endpoint	3	5	15	8	Head of Information Security
R-06	Model	Map	Jurisdictional and product-variant inconsistency	3	3	9	4	Compliance Operations Manager
R-07	Model	Manage	Endpoint availability and cost exposure	3	2	6	2	Head of Platform Engineering
R-08	Model	Govern	Vendor model lifecycle change	4	3	12	4	AI Governance Lead
R-09	Usage	Govern	Staff over-reliance	4	4	16	9	Customer Service Operations Director
R-10	Usage	Govern	Attribution and repudiation gap	3	4	12	3	Head of Information Security
R-11	Usage	Manage	Credential and session compromise	2	4	8	3	Head of Information Security

Five risks are High at inherent (R-01, R-02, R-04, R-05, R-09). After controls, none is. Section 6 examines the residual profile.

3.3 Prioritization analysis

Raw scoring produced a three-way tie at 16 and a two-way tie at 15, and so could not on its own tell the committee what to act on first. Five overlay factors were applied: regulatory sensitivity, external harm reach, detection lag, control readiness gap, and interaction effect. The overlay moves two risks up and two down.

Priority	Risk	Movement	Adjusted rationale
1	R-01 Ingestion boundary failure	Holds (16)	The only risk that is simultaneously regulator-notifiable, silent in accumulation, and almost entirely unbuilt. Also the precondition for the largest modelled financial exposure.

Priority	Risk	Movement	Adjusted rationale
2	R-02 Permission-trimming failure	Up 3 (15)	Highest single impact rating in the register. The only risk with no natural detection signal. It is also the containment control that caps R-05, so its failure compounds rather than stands alone.
3	R-05 Prompt injection at the inference endpoint	Up 2 (15)	Deliberate adversary, immediate exploitation, published technique base. Ranked below R-02 because permission-trimmed retrieval is what bounds its consequence.
4	R-04 Ungrounded regulated answer	Down 2 (16)	Reaches customers directly, which keeps it in the top five. Ranked below the above because harm is per-answer and bounded, existing quality assurance provides independent detection, and its mitigations are configuration rather than build.
5	R-09 Staff over-reliance	Down 2 (16)	A dependent amplifier rather than an independent source of loss — it converts R-04 and R-06 errors into customer harm. Ranking it higher would count the same loss event twice. This ordering reverses after controls; see Section 6.

R-03, R-08 and R-10 sit immediately below the line at 12. R-10 is flagged as a watch item: supervisory expectations around reconstructing AI-influenced decisions are tightening, and a shift in that expectation would move it above the line with no change to the system.

3.4 FAIR quantification

Scenario selected. Confidentiality breach of restricted content extracted from the knowledge assistant through prompt injection against the Azure OpenAI inference endpoint. Primary risk R-05, with R-01 as the enabling precondition.

This scenario was chosen because it is a discrete, countable loss event with a single identifiable attack path, its loss lands in categories a financial services executive prices routinely, and defensible external anchors exist for both loss components. R-01 and R-02 were considered and rejected as standalone scenarios because a control failure is not a loss event — it creates exposure but produces no loss until something extracts the data. R-04 was rejected because its loss event is a single wrong answer, giving a very high frequency and very low magnitude with a long tail that FAIR handles poorly at Contoso's current data maturity. R-09 was rejected because there is no defensible way to state how often over-reliance occurred.

FAIR parameter	Minimum	Most likely	Maximum
Loss Event Frequency (events per year)	0.10	0.25	0.50
Primary Loss Magnitude — incident response	\$100,000	\$250,000	\$1,000,000
Secondary Loss Magnitude — regulatory and legal	\$400,000	\$2,250,000	\$11,000,000
Total Loss Magnitude per event	\$500,000	\$2,500,000	\$12,000,000
Annualised Loss Expectancy (ALE)	\$50,000	\$625,000	\$6,000,000

All three input parameters are taken unchanged from the FAIR calculator supplied in the scenario package. No input has been invented, substituted or re-estimated.

Why the scenario is chained rather than single-risk

The supplied secondary loss band reaches \$11,000,000 in regulatory and legal exposure. On R-05 alone that figure is not defensible. Scope exclusion X-2 bars customer personal data from the index, so a prompt injection against a correctly bounded corpus extracts internal policy content — commercially sensitive, but not a notifiable personal-data breach and nowhere near a penalty of that scale.

The figure becomes credible only where R-01 has already failed: excluded content is present in the index despite the boundary rule, and injection is the mechanism that extracts it. Modelling the two together is not a convenience — it is what makes the supplied loss magnitudes honest.

Governance consequence. Because the secondary loss band depends on the R-01 precondition, ingestion controls exert more leverage on modelled exposure than endpoint controls do. Sensitivity analysis puts the ingestion control set at approximately 73 per cent reduction of the modelled maximum, against approximately 60 per cent for the endpoint control set, and approximately 89 per cent for both together. If nothing sensitive is in the index, the injection succeeds and the loss is modest.

Section 4: Threat Model Findings

4.1 Boundary and method

The STRIDE assessment is scoped to the Azure OpenAI inference endpoint and the trust boundaries that converge on it. The endpoint is not a single boundary but a point where five distinct ones meet: caller identity, retrieval authorisation, corpus integrity, generation behaviour, and evidence capture. This is why a single-layer control fails all of them at once, and it is the engineering problem ADR-001 addresses.

One threat is recorded per STRIDE category. Every threat traces back to a risk already in the register — no new risk is introduced — and every threat is paired with a mitigation in ADR-001. The security property each category violates is stated as defined by Microsoft; see Appendix C.

4.2 Threat findings

Threat ID	Category	Property violated	System element	Threat scenario	Risk	ADR pair
STRIDE-S	Spoofing	Authentication	Caller identity / session token	A phished or replayed staff credential is used to query the assistant. Content is returned at the victim's entitlement tier and the audit trail attributes it to them.	R-11	P-1
STRIDE-T	Tampering	Integrity	Retrieval corpus and search index	A corpus document is altered, or a superseded policy is left indexed, so the endpoint grounds answers in tampered or withdrawn content that inherits the citation's authority.	R-03	P-2
STRIDE-R	Repudiation	Non-repudiation	Endpoint telemetry and audit trail	An assistant-influenced action is disputed and Contoso cannot reconstruct the prompt, the grounding documents, or the output, because telemetry is incomplete or unattributed.	R-10	P-3
STRIDE-I	Information Disclosure	Confidentiality	Inference endpoint — prompt and completion path	A direct or document-borne prompt injection overrides the system prompt and causes the model to emit restricted content. Where R-01 has already failed, this is the extraction mechanism for the quantified loss event.	R-05 / R-01	P-4
STRIDE-D	Denial of Service	Availability	Inference endpoint — capacity and quota	Recursive prompting, scripting or token flooding drives the endpoint to its quota ceiling, throttling legitimate staff and accruing unbudgeted consumption charges.	R-07	P-5
STRIDE-E	Elevation of Privilege	Authorization	Retrieval authorisation layer	A user obtains documents above their entitlement tier through the retrieval layer rather than the identity layer — filter drift, an adversarial prompt widening scope, or an unlabelled document returned by default.	R-02	P-6
Threat	Status today		Note			
STRIDE-S	Mitigated		Control runs in the enterprise today and is extended to this workload.			
STRIDE-T	Open — pre-go-live		Control designed but not built; must be delivered before go-live.			
STRIDE-R	Open — pre-go-live		Control designed but not built; must be delivered before go-live.			
STRIDE-I	Open — pre-go-live		Control designed but not built; must be delivered before go-live.			

Threat ID	Category	Property violated	System element	Threat scenario	Risk	ADR pair
STRIDE-D	Open — pre-go-live		Control designed but not built; must be delivered before go-live.			
STRIDE-E	Open — review required		Design not yet settled; a decision is required before build. This is the highest-priority condition.			

Five of the six threats have no control in production today. Status here reflects implementation state, not residual risk: the register's residual scores assume every listed control is delivered. That distinction is the hinge of the recommendation in Section 7.

4.3 The two findings that matter most

Elevation of privilege is the sharpest finding. It is deliberately recast from the template's IT-provisioning bypass, because scope exclusion X-5 removes workflow execution entirely — there are no provisioning gates left to bypass. The honest threat for an advisory assistant is escalation through the retrieval layer: filter drift, an adversarial prompt widening scope, or an unlabelled document returned by default. A customer service representative surfaces compliance-restricted investigation material and nothing detects it, because a user shown too much does not complain.

Information disclosure is the most financially material. It is the only threat in the set that is quantified, and its magnitude depends on a second failure having already occurred. Direct injection is well understood; the harder variant is indirect injection embedded in an indexed document, where the payload arrives through retrieval rather than through the prompt. Input pattern matching cannot see it at all.

4.4 Register risks with no STRIDE pairing

Four risks carry no threat pairing. This is correct rather than a gap, and is recorded so the omission is not read as oversight.

Risk	Risk name	Why no STRIDE threat exists
R-04	Ungrounded regulated answer	Not an adversarial threat. Addressed by groundedness thresholds, abstention and compliance sampling.
R-06	Jurisdictional and product-variant inconsistency	A context-scoping defect, not an attack. Addressed by metadata filtering and refusal on unresolved scope.
R-08	Vendor model lifecycle change	Arises from the supplier's release cycle, not a threat actor. Addressed by version pinning and regression testing.
R-09	Staff over-reliance	A behavioural risk with no attacker. Addressed by training, attestation, interface design and quality assurance sampling.

4.5 Pairing to ADR-001

ADR-001, Defence-in-Depth Protection of the Azure OpenAI Inference Endpoint, records six threat-mitigation pairings, P-1 to P-6, one for each threat above. Each names Microsoft-native controls and states the trade-off Contoso accepts in adopting them. Six threats, six pairings, zero orphans; the pairing completeness check is reproduced in Appendix A of that record and verified in Appendix A of this report.

Section 5: Control Alignment Matrix

5.1 Method

Every control is mapped to a NIST AI RMF core function, to the corporate security strategy pillar it supports, to the risks and threats it addresses, and to its linkage with the governance recommendation in Section 7. The three pillars are: Confidentiality & Perimeter Security; Data Integrity & Provenance; and Auditability & Logging Non-Repudiation.

Four controls come from the existing AI controls inventory, and their commentary has been corrected where the inventory's own assessment was found to be inaccurate. Ten are new and required by ADR-001.

5.2 The matrix

Each control occupies two rows: the mapping, then the strategic commentary naming the pillar it supports and any coverage gap. The linkage column states how the control relates to the CONDITIONAL APPROVAL recommended in Section 7.

ID	Control	NIST function	Strategy pillar	Risks / threats	Timing	Governance linkage
C-01	Entra ID authentication, extended with phishing-resistant MFA, Conditional Access, Continuous Access Evaluation and Managed Identity	Govern / Manage	Pillar 1 — Confidentiality & Perimeter Security	R-11 / STRIDE-S	Pre-go-live	Condition satisfied
Supports the Confidentiality & Perimeter Security pillar by establishing a verified, device-compliant caller before retrieval and removing static key persistence. GAP CORRECTED: the inventory's claim that this 'fully meets the corporate perimeter pillar rules' is too broad — it establishes who the caller is, not what they may retrieve.						
C-02	Input regex token validation pipelines	Map / Measure	Pillar 2 — Data Integrity & Provenance	R-05 (partial) / STRIDE-I	Pre-go-live	Condition precedent — CP-4
Supports the Data Integrity & Provenance pillar by filtering known malicious input patterns. GAP CORRECTED: the inventory's 'no structural coverage gaps identified' is materially wrong. Pattern matching fails open against paraphrase, encoding variation and document-borne indirect injection, which it cannot see at all. Retained as a component, rejected as the control.						
C-03	Microsoft Purview immutable telemetry log storage	Govern / Measure	Pillar 3 — Auditability & Logging Non-Repudiation	R-10 / STRIDE-R	Pre-go-live (moved forward)	Condition precedent — CP-3
Supports the Auditability & Logging Non-Repudiation pillar by capturing user ID, prompt, grounding document versions and output hash in write-once storage. TIMING CORRECTED: scheduled by the inventory for 30 days post go-live; non-repudiation cannot be applied retrospectively and the design is fail-closed.						
C-04	Outbound PII content filters and cosine similarity limits	Measure / Manage	Pillar 1 — Confidentiality & Perimeter Security	R-05, R-01 / STRIDE-I	Within 30 days	30-day commitment — D-1
Supports the Confidentiality & Perimeter Security pillar at egress. GAP CONFIRMED: the inventory's own false-positive tuning gap is real — a compliance officer querying fraud investigation procedure is the canonical refusal. A documented human fallback is required from day one. An egress filter is also a last line, not a substitute for C-09.						
C-05	Azure AI Search security trimming: Entra ID group ACLs in a filterable field, OData filter derived server-side from the validated token, deny-by-default on unlabelled documents	Measure / Manage	Pillar 1 — Confidentiality & Perimeter Security (with Pillar 3 alerting)	R-02 / STRIDE-E	Pre-go-live	Condition precedent — CP-1 (highest priority)
Supports the Confidentiality & Perimeter Security pillar horizontally — inside the perimeter rather than at it. LARGEST FUNCTIONAL GAP: nothing in the existing inventory enforces entitlement at retrieval. Once network isolation closes the external perimeter this is the only remaining leakage path. Design not yet settled; delegated access unresolved.						
C-06	Azure AI Content Safety Prompt Shields (jailbreak and indirect attack	Measure / Manage	Pillar 2 — Data Integrity & Provenance	R-05, R-04 / STRIDE-I	Pre-go-live	Condition precedent — CP-4

ID	Control	NIST function	Strategy pillar	Risks / threats	Timing	Governance linkage
	detection) with groundedness detection and abstention					
Supports the Data Integrity & Provenance pillar by protecting the prompt template from adversarial manipulation and detecting document-borne injection that C-02 structurally cannot. Abstention below the groundedness threshold also serves R-04. GAP: false-positive rate unknown pre-deployment; a tuning period and a published abstention KPI are required.						
C-07	Azure Virtual Network isolation with private endpoint; public network access disabled	Govern / Manage	Pillar 1 — Confidentiality & Perimeter Security	R-05, R-11 / STRIDE-I, STRIDE-S	Pre-go-live	Condition precedent — CP-5
Supports the Confidentiality & Perimeter Security pillar at the network boundary by removing the public attack surface. No gap. One consequence for the committee: closing the external perimeter moves the residual leakage path inward to entitlement, which is why C-05 outranks this control in delivery priority despite being harder to build.						
C-08	Corpus integrity: immutable (WORM) blob storage, Azure RBAC write restriction to the ingestion managed identity, SHA-256 hash manifest verification, automated de-index on supersession	Manage / Measure	Pillar 2 — Data Integrity & Provenance	R-03 / STRIDE-T	Pre-go-live	Condition precedent — CP-5
Supports the Data Integrity & Provenance pillar by restricting write access to the knowledge base index and proving on a schedule that the corpus is unaltered. No structural gap. Accepted operational cost is a batch update cycle of up to 24 hours, mitigated by version and effective-date display in every citation.						
C-09	Pre-index Microsoft Purview DLP scanning with hard-fail quarantine, Information Protection sensitivity labelling, source repository classification and owner sign-off	Map / Govern	Pillar 1 — Confidentiality & Perimeter Security (with Pillar 2)	R-01 / STRIDE-I precondition	Pre-go-live	Condition precedent — CP-2
Supports the Confidentiality & Perimeter Security pillar at ingestion — enforcing the data boundary where content enters, not only where it leaves. HIGHEST-LEVERAGE GAP: the inventory contains no data loss prevention capability at all. FAIR sensitivity puts the ingestion control set at roughly 73 per cent reduction of modelled maximum exposure against roughly 60 per cent for endpoint controls.						
C-10	Azure API Management rate-limit and quota policies, gateway token caps, Provisioned Throughput Unit reservation, Cost Management budget alerts with circuit-breaker	Manage	PARTIAL — Pillar 3 only	R-07 / STRIDE-D	Pre-go-live	Condition precedent — CP-6; strategy finding S-1
Partial alignment. Consumption and per-identity anomaly telemetry serve the Auditability & Logging Non-Repudiation pillar. STRATEGY GAP: availability and cost resilience map to no existing pillar — the three pillars are the classical triad with availability omitted. A finding for the CISO, not a defect in this initiative.						
C-11	Model version pinning, Azure OpenAI deprecation calendar monitoring, benchmarked behavioural regression suite, change advisory board routing	Govern	Pillar 2 — Data Integrity & Provenance (with Pillar 3)	R-08 / no STRIDE pairing	Within 30 days	30-day commitment — D-2
Supports the Data Integrity & Provenance pillar by extending provenance from the data layer to the model layer, so an answer's lineage includes which model version produced it. GAP: no AI-specific change control exists; the general change process cannot detect behavioural drift because behaviour is not a configuration diff.						
C-12	Jurisdiction and product-generation metadata tagging with mandatory retrieval filtering; refusal when scope cannot be resolved	Map / Measure	Pillar 2 — Data Integrity & Provenance	R-06 / no STRIDE pairing	Within 30 days	30-day commitment — D-3
Supports the Data Integrity & Provenance pillar by validating that retrieved context matches the caller's regulatory and product context before synthesis. GAP: effectiveness depends on metadata completeness in source repositories, which is unverified. A corpus metadata audit is required.						
C-13	Groundedness and abstention KPIs as go-live exit criteria; weekly compliance sampling of 100 responses; restricted-topic deflection to human specialists	Measure	PARTIAL — Pillar 2 by extension	R-04, R-06 / no STRIDE pairing	Pre-go-live (exit criteria)	Condition precedent — CP-7; strategy finding S-2

ID	Control	NIST function	Strategy pillar	Risks / threats	Timing	Governance linkage
Mapped to Data Integrity & Provenance by extension, on the reading that an ungrounded answer is a provenance failure. STRATEGY GAP: no pillar addresses model reliability or answer quality directly — the strategy does not contemplate a control whose object is the truthfulness of generated output.						
C-14	Mandatory AI-use training with annual attestation, usage policy assigning outcome accountability to the employee, persistent interface disclaimer, citation-first answer layout, QA sampling of assistant-influenced interactions	Govern	PARTIAL — Pillar 3 by extension	R-09 / no STRIDE pairing	Pre-go-live	Condition precedent — CP-7; strategy finding S-2
Attestation records and QA evidence support the Auditability & Logging Non-Repudiation pillar by establishing who was accountable for acting on an answer. STRATEGY GAP: human factors and automation bias map to no pillar. This matters most of the three — R-09 carries the highest residual score in the register and is governed entirely by controls the strategy does not contemplate.						

5.3 Pillar coverage assessment

Pillar	Verdict	Assessment
Pillar 1 — Confidentiality & Perimeter Security	Aligned once conditions met	Served at four points — network (C-07), identity (C-01), retrieval entitlement (C-05) and ingestion (C-09) — with egress filtering (C-04) as a last line. Two of the five do not exist today and both are conditions precedent. Well served by the target architecture, materially under-served by the current inventory.
Pillar 2 — Data Integrity & Provenance	Aligned once conditions met	Corpus integrity (C-08) and prompt-template protection (C-06) address the pillar directly, and C-11 extends provenance from data to model version. The weakness is that C-02, the only integrity control in the existing inventory, was assessed by that inventory as gap-free when it is not.
Pillar 3 — Auditability & Logging Non-Repudiation	Aligned — one timing correction	Immutable telemetry (C-03) satisfies the pillar in substance. The only defect is scheduling: the inventory placed it 30 days after go-live, incompatible with a fail-closed design and with the pillar's own premise. Corrected to pre-go-live.

Risk classes with no corresponding pillar

Three risk classes this initiative introduces map to no existing pillar. These are gaps in the corporate security strategy, not in the initiative, and they do not gate the deployment decision — but leaving them unrecorded would be a governance failure in its own right.

Risk class	Control	Why it matters
Availability and cost resilience	C-10	The three pillars cover confidentiality, integrity and auditability — the classical triad with availability omitted. A metered AI service makes that omission visible in a way traditional infrastructure did not, because unavailability and unbudgeted cost arrive through the same failure.
Model reliability and answer quality	C-13	No pillar contemplates a control whose object is the truthfulness of generated output. C-13 is mapped to Data Integrity by extension, which is a reasonable reading but not what the pillar was written for.
Human factors and automation bias	C-14	No pillar addresses how staff interpret and act on output. The most consequential of the three: R-09 carries the highest residual score in the register and is governed entirely by controls the strategy does not contemplate.

5.4 Course corrections

Nine corrections are recommended. Five must be completed before deployment and form part of the conditions precedent in Section 7. Four are delivered during deployment, of which two are strategy-level findings for the Chief Information Security Officer that do not gate the decision. None requires the initiative to be deferred.

Ref	Course correction	Timing	Owner
CC-1	Move Purview immutable telemetry from 30 days post go-live to pre-go-live.	Before deployment	Head of Information Security
CC-2	Withdraw the inventory's 'no structural coverage gaps identified' assessment of input regex validation.	Before deployment	AI Governance Lead
CC-3	Add pre-index DLP scanning, sensitivity labelling and source classification. No DLP capability exists today.	Before deployment	Data Protection Officer
CC-4	Settle the security trimming design, including delegated access, then build and test it.	Before deployment	Head of Information Security
CC-5	Extend the corporate security strategy with an availability and resilience pillar, or formally record availability as accepted outside the AI security perimeter.	During deployment (strategy)	Chief Information Security Officer
CC-6	Extend the strategy to cover model reliability and human-factors risk classes.	During deployment (strategy)	Chief Information Security Officer
CC-7	Correct the inventory record claiming Entra ID authentication fully meets the perimeter pillar.	Before deployment	AI Governance Lead
CC-8	Build the benchmarked behavioural regression suite for model change control.	During deployment (30 days)	AI Governance Lead
CC-9	Complete a corpus metadata audit to verify jurisdiction and product-generation tagging.	During deployment (30 days)	Product Owner, Knowledge Assistant

Section 6: Residual Risk Assessment

6.1 Method and basis

Residual risk is the exposure remaining after the controls described in Section 5 are delivered and operating. Every residual score below is attributable to named controls; no reduction is claimed without a control behind it. Preventive controls reduce likelihood; detective and response controls reduce impact.

6.2 Residual profile

Band	Inherent	Residual	Movement
High (13–25)	5 risks	0 risks	All five High risks move out of the band
Medium (6–12)	6 risks	5 risks	R-01, R-02, R-04, R-05, R-09
Low (1–5)	0 risks	6 risks	R-03, R-06, R-07, R-08, R-10, R-11

No risk remains in the High band. The five that remain Medium are set out below with the reason each does not fall further.

6.3 The five residual Medium risks

Risk	Risk name	Residual	Why it does not fall further
R-09	Staff over-reliance	9	Automation bias does not respond well to training and disclaimers, and it strengthens as the tool proves useful. Deliberately the least-reduced risk in the register: scoring it down would misrepresent what controls C-14 can actually achieve. It becomes the leading residual concern, reversing its fifth place at inherent.
R-01	Ingestion boundary failure	8	Likelihood falls sharply under C-09's hard-fail quarantine, but impact is held: once excluded content is indexed and retrieved, the breach has occurred. Detection speed improves; severity does not.
R-02	Permission-trimming failure	8	C-05 is strongly preventive, but the impact of a compliance-restricted disclosure remains high. Retrieval alerting shortens detection from months to hours, which is why impact falls from 5 to 4 rather than staying at 5.
R-05	Prompt injection at the inference endpoint	8	Prompt injection is not solved, only bounded. C-06 reduces likelihood; permission-trimmed retrieval caps the blast radius at the caller's entitlement, which is why R-02's delivery matters to R-05's residual.
R-04	Ungrounded regulated answer	6	Abstention below the groundedness threshold prevents the highest-consequence answers being generated at all, and weekly compliance sampling shortens the window before a systematic error is caught. Residual impact of 3 reflects that a wrong answer can still reach a customer between samples.

6.4 Residual financial exposure

The unmitigated band for the principal scenario is \$50,000 minimum, \$625,000 most likely, \$6,000,000 maximum. Sensitivity modelling of the delivered control sets indicates an indicative residual band of approximately \$7,000 minimum, \$70,000 most likely, \$640,000 maximum — a reduction of roughly 89 per cent at the maximum.

This residual figure should be treated as indicative only. The control-effectiveness factors behind it are the author's estimates rather than scenario data, and they are flagged as such in the quantification model. The unmitigated band remains the figure of record for the committee, and no decision in this report depends on the residual estimate.

6.5 Is the residual acceptable for deployment?

Acceptable — conditionally.

The residual profile — no High risks, five Medium, six Low, on an internal advisory system with no customer-facing access and no personal data in the corpus — sits within Contoso's stated appetite. Acceptance rests on one condition, stated below.

The condition is this: **the profile above is a projected residual, not an observed one.** It assumes fourteen controls are delivered and operating. Thirteen of them are not. One control runs in production today, and the STRIDE assessment found five of six threats with no mitigation in place. The residual scores in Section 3 are therefore a statement about the target architecture, not about the system as it stands.

This distinction is the whole of the governance question. If the committee accepts the residual profile, it is accepting a control set that has yet to be built — which is a reasonable thing to do, provided the acceptance is made conditional on the build being completed and verified. That is precisely the recommendation in Section 7.

Two residual exposures should be visible to the committee as ongoing rather than closable. R-09 will remain Medium indefinitely; automation bias is managed, not eliminated, and the committee should expect it to be a standing item rather than a project deliverable. And the low-confidence assumption A-03 — the reconstructed processing record — remains open until the Data Protection Officer confirms it.

Section 7: Governance Recommendation

RECOMMENDATION: CONDITIONAL APPROVAL

Approve production deployment of the GenAI Knowledge Assistant, subject to eight conditions precedent delivered and independently verified before go-live, and three further commitments delivered within 30 days of go-live.

7.1 Why conditional, and not the alternatives

Section 6 concluded that the residual profile is acceptable but projected: no risk remains in the High band once the controls in Section 5 are delivered, and thirteen of the fourteen are not yet delivered. Three courses follow from that finding, and only one of them is proportionate.

Option	Assessment
Approve	Rejected. Unconditional approval would accept a residual profile that depends on a control set which does not exist. The five High inherent risks are only Medium on paper.
Defer	Rejected. Disproportionate. No risk in the register is unacceptable in principle, every gap has an identified remedy with a named owner, and the largest gaps are buildable inside the existing Azure tenant with no new supplier. Deferral would impose cost without reducing risk.
Conditional approval	Recommended. It matches the finding exactly: the design is sound, the exposure is understood and priced, and the outstanding work is deliverable and verifiable before the system reaches a user.

7.2 Conditions precedent — required before go-live

Ref	Condition	Owner	Timing	Verification test
CP-1	Retrieval entitlement enforcement (C-05) designed, built and tested. The delegated-access design question must be resolved and recorded.	Head of Information Security	Before go-live	Entitlement regression suite passing on the production index; delegated-access decision minuted
CP-2	Ingestion boundary enforcement (C-09): pre-index DLP with hard-fail quarantine, sensitivity labelling, and source classification with owner sign-off.	Data Protection Officer	Before go-live	DLP quarantine demonstrated on a seeded test document; every source repository classified and signed off
CP-3	Immutable, fail-closed telemetry (C-03) operating before the first production query.	Head of Information Security	Before go-live	Fail-closed behaviour tested; Internal Audit independent read access confirmed
CP-4	Adversarial input and groundedness defences (C-02 supplemented by C-06), with a documented human fallback path for blocked queries.	Head of Information Security, with Compliance Operations Manager	Before go-live	Red-team test report accepted; abstention-rate baseline published; fallback path documented and staffed
CP-5	Corpus integrity and network isolation (C-07, C-08): WORM storage, hash manifest verification, automated de-index on supersession, public network access disabled.	Head of Platform Engineering, with Product Owner, Knowledge Assistant	Before go-live	Hash verification job running with alerting; public network access confirmed disabled by configuration review
CP-6	Consumption controls (C-10): rate limits, token caps, provisioned capacity and budget alerts with a defined circuit-breaker.	Head of Platform Engineering	Before go-live	Rate limit and budget alert tested end to end
CP-7	Human-factors controls and quality exit criteria (C-13, C-14): training with attestation, usage policy, interface	AI Governance Lead, with Customer Service Operations Director	Before go-live	Training completion at or above 95 per cent of the licensed population; groundedness exit criteria evidenced

Ref	Condition	Owner	Timing	Verification test
	disclaimer, groundedness exit criteria met.			
CP-8	Controls inventory record corrected: withdraw the 'no structural coverage gaps' assessment of C-02 and the 'fully meets the perimeter pillar' claim for C-01.	AI Governance Lead	Before go-live	Corrected inventory reissued and circulated to the committee

Verification of each condition is evidenced to the AI Governance Lead, who reports completion to the Executive Risk Committee before go-live is authorised. No condition is self-certified by the team that built the control.

7.3 Commitments — within 30 days of go-live

Ref	Commitment	Owner	Timing
D-1	Outbound PII filter tuning completed and the false-positive rate reported to the committee (C-04).	Head of Information Security	Within 30 days of go-live
D-2	Benchmarked behavioural regression suite built and run against the pinned model version (C-11).	AI Governance Lead	Within 30 days of go-live
D-3	Corpus metadata audit completed to verify jurisdiction and product-generation tagging (C-12).	Product Owner, Knowledge Assistant	Within 30 days of go-live

7.4 Strategy-level findings for the Chief Information Security Officer

Two findings concern the corporate security strategy rather than this initiative. They do not gate the deployment decision and should not delay it, but they should not be left unrecorded either.

Ref	Finding	Owner
S-1	Availability and cost resilience map to no existing strategy pillar. Extend the strategy with a resilience pillar, or formally record availability as accepted outside the AI security perimeter.	Chief Information Security Officer
S-2	Model reliability and human-factors risk classes map to no existing pillar. The strategy was written for classical information security and does not contemplate controls whose object is the truthfulness of generated output or the behaviour of the people acting on it.	Chief Information Security Officer

7.5 What would change this recommendation

If CP-1 or CP-2 cannot be delivered before go-live, the recommendation changes to DEFER. Without retrieval entitlement enforcement, R-02 remains at its inherent score of 15. Without ingestion boundary enforcement, R-01 remains at 16 and the FAIR loss path stays open at its full modelled magnitude. Two risks in the High band exceeds appetite for this initiative, and no compensating control exists that would bring either down.

If the Data Protection Officer cannot confirm the processing basis in assumption A-03, go-live should be held pending that confirmation. This is a documentation dependency rather than a control failure, but the organisation should not process staff prompt content at scale without a settled processing record.

The 30-day commitments D-1 to D-3 do not gate go-live. Failure to deliver them within the window should be escalated to the committee as a breach of the approval terms rather than absorbed by the programme.

7.6 Monitoring and review

- The AI Governance Lead reports condition completion to the committee before go-live is authorised, with verification evidence attached.

- A 30-day post-deployment review is presented to the committee covering the three commitments, observed injection-attempt telemetry, groundedness and abstention rates, and any entitlement alerts raised.
- The risk register is reviewed quarterly by the AI Governance Lead with risk owners, and the FAIR model is re-run at six months once observed frequency data replaces the estimated Loss Event Frequency.
- R-09 is treated as a standing committee item rather than a closable action, on the basis set out in Section 6.3.
- Any change to the pinned Azure OpenAI model version triggers re-execution of the regression suite and a report to the committee before promotion.

Appendix A: Consistency Cross-Check

Performed across Sections 2 to 7 before submission. Each check was verified against the artifact concerned, not asserted from memory; the STRIDE orphan check and all arithmetic were verified programmatically.

#	Check	Result	Status
1	Every risk named in Section 3 appears in the same form in all subsequent references.	Eleven risks R-01 to R-11 are named once in Section 3.2 and every later reference uses the same short name and identifier. No risk is introduced after Section 3.	PASS
2	Every STRIDE threat in Section 4 has a paired mitigation in Section 5 / ADR-001.	Six threats, six pairings P-1 to P-6. Verified programmatically in the STRIDE workbook's orphan-check sheet, and recorded in Appendix A of ADR-001. Zero orphans.	PASS
3	Section 5 commentary references specific corporate security strategy pillars.	All fourteen control commentaries name their pillar in the strategy's own words. Three controls are marked PARTIAL where no pillar exists to name.	PASS
4	Section 6 draws its residual conclusion from the controls described in Section 5.	Every residual score in Section 6 is attributed to named controls C-01 to C-14. No residual reduction is claimed without a control behind it.	PASS
5	Section 7 follows directly from Section 6.	Section 6 concludes the residual profile is acceptable but projected, not observed. Section 7 recommends conditional approval on exactly that basis, and states the condition failures that would convert it to defer.	PASS
6	Section 1 accurately reflects Sections 2 to 7.	The Executive Summary was written last. Its scope, top three risks, ALE band, threat findings, recommendation and residual posture were checked line by line against the sections they summarise.	PASS
7	Scope boundaries hold at every section transition.	No section references an out-of-scope element X-1 to X-11. The advisory-only boundary (X-5) is carried consistently, including in the recast of the elevation-of-privilege threat.	PASS
8	The ALE is presented as a three-value band, never a point estimate.	Minimum, most likely and maximum are quoted together in Sections 1, 3.4 and 6.4. No single-point figure appears anywhere in the report.	PASS
9	Recommendations name owners and timelines.	Eight conditions precedent and three 30-day commitments each carry a named role, a timing, and a verification test. Two strategy findings are assigned to the CISO.	PASS
10	Framework references verified against authoritative sources.	The four NIST AI RMF core functions and the six STRIDE categories with the security property each violates were verified against NIST and Microsoft primary sources. No CVE identifiers, subcategory numbers or statistics from secondary sources are cited anywhere in this report.	PASS

Appendix B: Documented Assumptions

Each assumption below is not explicitly stated in the scenario brief. Reviewers should evaluate them directly.

Ref	Assumption	Why it is needed	Confidence
A-01	The platform is Azure OpenAI Service inside Contoso's private Azure tenant.	The brief states only 'a foundational LLM hosted within a private corporate cloud tenant'. Azure is inferred from Entra ID and Microsoft Purview in the controls inventory.	High
A-02	The subject is the internal knowledge assistant for customer service, operations and compliance — not the HR onboarding assistant the scenario brief is titled for.	The brief and the committee's request describe different systems. The brief's architecture, guardrail pattern and data-boundary discipline are carried forward; its HR user population and IT-ticket automation are not.	High — confirm with committee
A-03	No RoPA excerpt was supplied. Processing is assumed as: purpose — internal staff knowledge retrieval; personal data — staff identity attributes and prompt-log content only; lawful	The report cannot assert data protection compliance without a processing record.	LOW — must be confirmed with the Data Protection Officer before go-live

Ref	Assumption	Why it is needed	Confidence
	basis — legitimate interest; retention — per corporate log retention schedule.		
A-04	Version 1 is advisory and read-only; no downstream workflow triggering or transaction execution.	The committee's request describes retrieval and synthesis only.	High
A-05	The corpus is limited to internal policy documents, product guides and procedures on an approved-source allow-list.	Mirrors the brief's ingestion safe zone, generalised to the operational corpus.	High
A-06	The three corporate security strategy pillars are those named in the ADR and Alignment Matrix templates.	The scenario brief contains no pillars section.	High
A-07	The existing AI controls inventory comprises Entra ID token authentication, input validation pipelines, Purview immutable logging and outbound PII filters.	The brief contains no controls inventory; these are the four controls carried in the Alignment Matrix.	Medium
A-08	Contoso operates across both US and EU jurisdictions.	Needed to justify the jurisdictional-conflict risk (R-06).	Medium
A-09	The user population is approximately 2,000 staff across the three functions.	Needed to size exposure and rate-limiting thresholds.	Low — indicative only
A-10	Go-live is targeted within 30 days of committee approval, with a 90-day post-deployment assurance window.	Aligns to the committee's stated decision timetable.	Medium

Appendix C: Framework Reference Verification

Framework references in this report were verified against primary sources before inclusion. No CVE identifiers, NIST subcategory numbers, or statistics from secondary sources are cited anywhere in this report; where a figure is used, it comes from the scenario package or from arithmetic performed on it.

NIST AI Risk Management Framework 1.0 — four core functions

Function	Verified description
Govern	Cultivates and implements a culture of risk management within organisations designing, developing, deploying, evaluating or acquiring AI systems.
Map	Establishes the context to frame risks related to an AI system and identifies potential impacts across the AI lifecycle.
Measure	Employs quantitative, qualitative or mixed-method tools to analyse, assess, benchmark and monitor AI risk and related impacts.
Manage	Allocates risk resources to mapped and measured risks on a regular basis, and develops plans to respond to, recover from and communicate about incidents.

Source: NIST AI 100-1, Artificial Intelligence Risk Management Framework (AI RMF 1.0), January 2023 — verified against the NIST AI Resource Center, airc.nist.gov/airmf-resources/airmf/5-sec-core/ and nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf.

STRIDE — six categories and the security property each violates

Category	Property violated	Verified definition
Spoofing	Authentication	Illegally accessing and then using another user's authentication information.
Tampering	Integrity	Malicious modification of data, whether at rest in persistent storage or in transit between systems.

Category	Property violated	Verified definition
Repudiation	Non-repudiation	A user denies performing an action without other parties having any way to prove otherwise.
Information Disclosure	Confidentiality	Exposure of information to individuals who are not supposed to have access to it.
Denial of Service	Availability	Denying service to valid users, for example by making a system temporarily unavailable or unusable.
Elevation of Privilege	Authorization	An unprivileged user gains privileged access sufficient to compromise or destroy the system.

Source: Microsoft Learn, 'Threats — Microsoft Threat Modeling Tool', learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats.

Appendix D: Generative AI Usage Log

This appendix replaces the Non-Use Governance Attestation carried in the report template. That attestation certifies that no generative AI system was used to produce the report's quantitative thresholds or technical metrics. Generative AI assistance was used in preparing this report, so the attestation could not be signed truthfully. An accurate usage log is recorded instead, which also satisfies the audit-trail requirement more completely than a non-use declaration would.

Part 1 — Statement of AI assistance

Item	Record
Tool used	Claude (Anthropic), accessed through the Claude Cowork interface
Period of use	August 2026, during preparation of this report and its supporting artifacts
Purpose	Structuring the analysis, drafting narrative text, constructing the register, quantification model, threat worksheet, decision record and alignment matrix
What the tool drafted	Risk descriptions and scoring rationale; threat scenarios and countermeasure lists; control commentary; the narrative of all seven sections; the structure and formatting of all supporting artifacts
What the tool did not produce	The FAIR input parameters, which are taken unchanged from the scenario package; the scenario brief; the supplied templates; the corporate security strategy pillars
Quantitative inputs	No quantitative risk threshold in this report originates with the AI tool. Loss Event Frequency and both loss magnitude components are the values supplied in the scenario package FAIR Calculator Template. All derived figures are arithmetic on those inputs.

Part 2 — Human verification record

The following corrections and verifications were identified and applied during preparation. They are recorded so a reviewer can see the AI output was audited rather than accepted.

Ref	Verification or correction applied	Type
V-1	FAIR secondary loss band challenged: an \$11,000,000 regulatory exposure is not defensible against a corpus from which personal data is excluded. Scenario re-scoped as a chained loss path, R-01 enabling R-05.	Analytical correction
V-2	Risk identifier collision between the report template and the register template reconciled into a single authoritative scheme, R-01 to R-11.	Structural correction
V-3	The controls inventory's claim that input regex validation has 'no structural coverage gaps identified' withdrawn as materially wrong.	Source correction

Ref	Verification or correction applied	Type
V-4	The controls inventory's claim that Entra ID authentication 'fully meets the corporate perimeter pillar rules' corrected to the identity component only.	Source correction
V-5	Purview immutable telemetry moved from 30 days post go-live to pre-go-live, on the grounds that non-repudiation cannot be applied retrospectively.	Timing correction
V-6	STRIDE elevation-of-privilege threat recast from IT-provisioning bypass to retrieval-scope escalation, to match the advisory-only scope boundary.	Scope correction
V-7	NIST AI RMF core function descriptions and STRIDE category definitions verified against NIST and Microsoft primary sources; see Appendix C.	Reference verification
V-8	All arithmetic in the register and the FAIR model independently recomputed; inherent and residual scores and the ALE band confirmed.	Computational verification
V-9	STRIDE-to-ADR pairing completeness verified programmatically; six threats, six pairings, zero orphans.	Structural verification

Part 3 — Author attestation

I confirm that I have reviewed the content of this report and its supporting artifacts; that the analysis, judgements and recommendation reflect my professional assessment; that the generative AI assistance described above is accurately recorded; and that the framework references have been verified against the sources cited in Appendix C.

Name	
Role	AI Governance Lead, Contoso Financial Service
Signature	
Date	